



WhatsApp Handoff

STATUS

Azure webhook is live. Twilio still needs a WhatsApp sender or Sandbox configuration in the Twilio console.

Table of Contents

- Goal
- Current Backend Endpoint
- Environment
- Request Handling
- Provider Options
- Current Twilio Root Cause
- Rodrigo Tasks
- Local Test
- Security Tests
- Demo Positioning

Owner: Rodrigo

Status: Azure webhook is live. Twilio still needs a WhatsApp sender or Sandbox configuration in the Twilio console.

Goal

Let an approved business owner ask operational questions through WhatsApp and receive answers from the same backend tools used by the web app.

Current Backend Endpoint

```
POST /webhooks/whatsapp
```

Current hosted webhook URL:

```
https://jhonny-retail-api-a92e4ffb.azurewebsites.net/webhooks/whatsapp
```

The FastAPI webhook uses the same agent path as the app chat endpoint:

```
POST /chat
```

The endpoint accepts:

- Twilio-style form payloads with `From` and `Body`
- WhatsApp Cloud API-style JSON webhook payloads

If the request is Twilio form encoded, the backend returns TwiML. If it is JSON, the backend returns JSON with the answer and selected tool:

```
{
  "answer": "Today's sales are EUR 494.75 from 11 orders.",
  "tool": "get_today_sales"
}
```

The agent keeps WhatsApp answers shorter than app answers and avoids customer personal data.

Environment

```
WHATSAPP_ALLOWED_NUMBERS=351900000000,351911111111
WHATSAPP_RATE_LIMIT_PER_MINUTE=20
PUBLIC_WHATSAPP_WEBHOOK_URL=https://your-public-url/webhooks/whatsapp
TWILIO_AUTH_TOKEN=replace-with-twilio-auth-token
WHATSAPP_APP_SECRET=replace-with-meta-app-secret
```

If `WHATSAPP_ALLOWED_NUMBERS` is empty, all senders are allowed. For a real pilot, set this to the approved phone numbers only.

For Twilio, set `TWILIO_AUTH_TOKEN` and keep `PUBLIC_WHATSAPP_WEBHOOK_URL` equal to the webhook URL configured in Twilio. For Meta WhatsApp Cloud API, set `WHATSAPP_APP_SECRET` to verify `X-Hub-Signature-256`. If these secrets are absent, local testing still works, but production signature checks are disabled.

Request Handling

Step	Behavior
Parse payload	Reads JSON bodies for Meta Cloud API or form-encoded bodies for Twilio

Step	Behavior
Verify signature	Uses Twilio SHA1 signature or Meta SHA256 signature when the relevant secret is configured
Extract sender	Normalizes Twilio <code>whatsapp:+...</code> or Meta <code>messages[0].from</code> into a phone number
Check allowlist	Rejects unauthorized senders with HTTP 403 when <code>WHATSAPP_ALLOWED_NUMBERS</code> is set
Check rate limit	Rejects excess messages with HTTP 429 based on <code>WHATSAPP_RATE_LIMIT_PER_MINUTE</code>
Extract message	Uses Twilio <code>Body</code> or Meta <code>messages[0].text.body</code>
Answer question	Calls the same <code>RetailAgent</code> path with <code>channel=\"whatsapp\"</code>
Return response	Returns TwiML XML for Twilio or JSON for Meta/local tests

Provider Options

Option	When To Use	Notes
Twilio WhatsApp sandbox	Fastest demo path	Good for testing inbound/outbound behavior quickly
Meta WhatsApp Cloud API	Better production path	Requires Meta setup, webhook URL, and app secret
Local JSON test	Backend development	Does not require provider setup, but does not prove WhatsApp delivery

Current Twilio Root Cause

The Twilio account currently shows no active phone numbers. That screen is not enough to make WhatsApp work.

For a quick pilot, use the **Twilio WhatsApp Sandbox** instead of the Active Numbers screen:

1. In Twilio Console, go to **Messaging > Try it out > Send a WhatsApp message**.
2. Follow Twilio's join instruction from the target WhatsApp phone, usually a message like `join <sandbox-code>` to the Twilio sandbox WhatsApp number.
3. Set **When a message comes in** to:

```
https://jhonny-retail-api-a92e4ffb.azurewebsites.net/webhooks/whatsapp
```

4. Use method **HTTP POST**.
5. Send a WhatsApp message such as `How much did we sell today?`.

If using a production WhatsApp sender instead of the Sandbox, the Twilio account must have an approved WhatsApp sender. A normal Twilio trial with no active number/sender will not deliver WhatsApp messages to this backend.

Rodrigo Tasks

1. Choose provider:
 - Fastest demo: Twilio WhatsApp sandbox
 - Better production path: Meta WhatsApp Business Cloud API
2. Point inbound WhatsApp messages to:

```
https://jhonny-retail-api-a92e4ffb.azurewebsites.net/webhooks/whatsapp
```

3. For local testing, expose the local backend with a tunnel such as ngrok or Cloudflare Tunnel.

4. Test these prompts:

```
How much did we sell today?
What is the stock value?
What categories sold today?
What is low stock?
What should Jhonny focus on today?
Are purchases too high compared with sales?
```

5. Add production safeguards before a client rollout:

- Set `TWILIO_AUTH_TOKEN` in Azure from the Twilio account auth token
- Keep `PUBLIC_WHATSAPP_WEBHOOK_URL` exactly equal to the Twilio webhook URL
- Restrict `WHATSAPP_ALLOWED_NUMBERS` to approved phone numbers after the sandbox sender phone is known
- Confirm inbound and outbound message logs
- Keep rate limits enabled
- Avoid sending sensitive customer data over WhatsApp

Local Test

With the backend running on `http://127.0.0.1:8000`:

```
Invoke-RestMethod `
  -Uri http://127.0.0.1:8000/webhooks/whatsapp `
  -Method POST `
  -ContentType "application/json" `
  -Body '{"From":"351900000000","Body":"How much did we sell today?"}'
```

For Twilio-style form payloads:

```
Invoke-RestMethod `
  -Uri http://127.0.0.1:8000/webhooks/whatsapp `
  -Method POST `
  -ContentType "application/x-www-form-urlencoded" `
  -Body "From=whatsapp:%2B351900000000&Body=How%20much%20did%20we%20sell%20today%3F"
```

Cloud hosting is not required for app development. Only add a public URL when WhatsApp provider testing needs inbound internet access.

Security Tests

Run the local API security regression before a live WhatsApp demo:

```
py scripts/evaluate_api_security.py
```

This checks:

- allowed and blocked sender handling
- per-sender rate limiting
- Twilio signature verification
- Meta signature verification

Demo Positioning

WhatsApp is the fast owner channel. The app remains the primary review surface for dashboards, evidence, and richer analytics; WhatsApp is for short answers while the owner is on the shop floor.

Generated from Markdown with the EY-Parthenon styled Company Documents Cursor skill.